

ZAP by Checkmarx

Scanning Report

Generated with  ZAP on Sun 12 Apr 2026, at 08:03:46

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Contents

- [About This Report](#)
 - [Report Parameters](#)
- [Summaries](#)
 - [Alert Counts by Risk and Confidence](#)
 - [Alert Counts by Site and Risk](#)
 - [Alert Counts by Alert Type](#)
 - [Insights](#)
- [Alerts](#)
 - [Risk=Medium, Confidence=High \(1\)](#)
 - [Risk=Medium, Confidence=Medium \(2\)](#)
 - [Risk=Low, Confidence=Medium \(2\)](#)
 - [Risk=Informational, Confidence=High \(1\)](#)

- [Risk=Informational, Confidence=Medium \(3\)](#)
- [Appendix](#)
 - [Alert Types](#)

About This Report

Report Parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

- <http://16.171.226.110:8080>

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: [High](#), [Medium](#), [Low](#), [Informational](#)

Excluded: None

Confidence levels

Included: [User Confirmed](#), [High](#), [Medium](#), [Low](#)

Excluded: [User Confirmed](#), [High](#), [Medium](#), [Low](#), [False Positive](#)

Summaries

Alert Counts by Risk and Confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence				
Risk		User Confirmed	High	Medium	Low	Total
	High	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)
	Medium	0 (0.0%)	1 (11.1%)	2 (22.2%)	0 (0.0%)	3 (33.3%)
	Low	0 (0.0%)	0 (0.0%)	2 (22.2%)	0 (0.0%)	2 (22.2%)
	Informational	0 (0.0%)	1 (11.1%)	3 (33.3%)	0 (0.0%)	4 (44.4%)
	Total	0 (0.0%)	2 (22.2%)	7 (77.8%)	0 (0.0%)	9 (100%)

Alert Counts by Site and Risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

		Risk			
		High	Medium	Low	Informational
		(= High)	(>= Medium)	(>= Low)	(>= Informational)
Site	http://16.171.226.110:8080	0	3	2	4
		(0)	(3)	(5)	(9)

Alert Counts by Alert Type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
Buffer Overflow	Medium	5 (55.6%)
Content Security Policy (CSP) Header Not Set	Medium	1 (11.1%)
Missing Anti-clickjacking Header	Medium	1 (11.1%)
Cookie without SameSite Attribute	Low	1 (11.1%)
X-Content-Type-Options Header Missing	Low	5 (55.6%)
Authentication Request Identified	Informational	1 (11.1%)
Total		9

Alert type	Risk	Count
Modern Web Application	Informational	1 (11.1%)
Session Management Response Identified	Informational	1 (11.1%)
User Agent Fuzzer	Informational	5 (55.6%)
Total		9

Insights

This table shows information that is likely to be very relevant to you, but which is not related to vulnerabilities, or potentially even related to the application in question.

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP errors logged - see the zap.log file for details	3
Low	Warning		ZAP warnings logged - see the zap.log file for details	151
Low	Exceeded High	http://16.171.26.110:8080	Percentage of responses with status code 4xx	81 %
Info	Informational	http://127.0.0.1:49898	Percentage of responses with status code 2xx	100 %
Info	Informational	http://127.0.0.1	Percentage of endpoints with	30 %

Level	Reason	Site	Description	Statistic
		:49898	content type image/png	
Info	Informat ional	http://1 27.0.0.1 :49898	Percentage of endpoints with content type text/css	10 %
Info	Informat ional	http://1 27.0.0.1 :49898	Percentage of endpoints with content type text/html	50 %
Info	Informat ional	http://1 27.0.0.1 :49898	Percentage of endpoints with content type text/javascript	10 %
Info	Informat ional	http://1 27.0.0.1 :49898	Percentage of endpoints with method GET	100 %
Info	Informat ional	http://1 27.0.0.1 :49898	Count of total endpoints	10
Info	Informat ional	http://1 6.171.2 26.110: 8080	Percentage of responses with status code 2xx	18 %
Info	Informat ional	http://1 6.171.2 26.110: 8080	Percentage of endpoints with content type application/json	62 %
Info	Informat ional	http://1 6.171.2 26.110: 8080	Percentage of endpoints with content type application/pdf	6 %

Level	Reason	Site	Description	Statistic
Info	Informational	http://16.171.26.110:8080	Percentage of endpoints with content type image/x-icon	6 %
Info	Informational	http://16.171.26.110:8080	Percentage of endpoints with content type text/css	6 %
Info	Informational	http://16.171.26.110:8080	Percentage of endpoints with content type text/html	6 %
Info	Informational	http://16.171.26.110:8080	Percentage of endpoints with content type text/javascript	6 %
Info	Informational	http://16.171.26.110:8080	Percentage of endpoints with content type text/plain	6 %
Info	Informational	http://16.171.26.110:8080	Percentage of endpoints with method GET	75 %
Info	Informational	http://16.171.26.110:8080	Percentage of endpoints with method POST	18 %
Info	Informational	http://16.171.26.110:8080	Percentage of endpoints with method PUT	6 %

Level	Reason	Site	Description	Statistic
Info	Informational	http://16.171.26.110:8080	Count of total endpoints	16
Info	Exceeded Low	http://16.171.26.110:8080	Percentage of slow responses	12 %
Info	Informational	http://clients2.google.com	Percentage of responses with status code 2xx	100 %
Info	Informational	http://clients2.google.com	Percentage of endpoints with content type application/json	100 %
Info	Informational	http://clients2.google.com	Percentage of endpoints with method GET	100 %
Info	Informational	http://clients2.google.com	Count of total endpoints	1
Info	Informational	https://accounts.google.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://accounts.google.com	Percentage of endpoints with content type application/binary	100 %

Level	Reason	Site	Description	Statistic
Info	Informational	https://accounts.google.com	Percentage of endpoints with method POST	100 %
Info	Informational	https://accounts.google.com	Count of total endpoints	1
Info	Informational	https://accounts.google.com	Percentage of slow responses	100 %
Info	Informational	https://android.clients.google.com	Percentage of responses with status code 2xx	44 %
Info	Informational	https://android.clients.google.com	Percentage of responses with status code 3xx	55 %
Info	Informational	https://android.clients.google.com	Percentage of endpoints with content type application/x-protobuf	33 %
Info	Informational	https://android.clients.google.com	Percentage of endpoints with content type text/plain	66 %
Info	Informational	https://android.clients.google.com	Percentage of endpoints with	100 %

Level	Reason	Site	Description	Statistic
Info	Informational	clients.google.com	method POST	3
		https://android.clients.google.com	Count of total endpoints	
Info	Informational	https://android.clients.google.com	Percentage of slow responses	44 %
Info	Informational	https://chrome.webstore.googleapis.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://chrome.webstore.googleapis.com	Percentage of endpoints with content type application/x-protobuf	100 %
Info	Informational	https://chrome.webstore.googleapis.com	Percentage of endpoints with method POST	100 %
Info	Informational	https://chrome.webstore.google	Count of total endpoints	1

Level	Reason	Site	Description	Statistic
		apis.co m		
Info	Informat ional	https:// chrome webstor e.google apis.co m	Percentage of slow responses	100 %
Info	Informat ional	https:// content- autofill. googlea pis.com	Percentage of responses with status code 2xx	100 %
Info	Informat ional	https:// content- autofill. googlea pis.com	Percentage of endpoints with content type application/x- protobuf	12 %
Info	Informat ional	https:// content- autofill. googlea pis.com	Percentage of endpoints with content type text/plain	87 %
Info	Informat ional	https:// content- autofill. googlea pis.com	Percentage of endpoints with method GET	87 %
Info	Informat ional	https:// content- autofill. googlea pis.com	Percentage of endpoints with method POST	12 %

Level	Reason	Site	Description	Statistic
Info	Informational	https://content-autofill.googleapis.com	Count of total endpoints	16
Info	Informational	https://content-autofill.googleapis.com	Percentage of slow responses	4 %
Info	Informational	https://optimizationguide-pa.googleapis.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://optimizationguide-pa.googleapis.com	Percentage of endpoints with content type application/x-protobuf	50 %
Info	Informational	https://optimizationguide-pa.googleapis.com	Percentage of endpoints with content type text/html	50 %
Info	Informational	https://optimizationguide-pa.goog	Percentage of endpoints with method GET	50 %

Level	Reason	Site	Description	Statistic
		leapis.com		
Info	Informational	https://optimizationguide-pa.googleapis.com	Percentage of endpoints with method POST	50 %
Info	Informational	https://optimizationguide-pa.googleapis.com	Count of total endpoints	2
Info	Informational	https://optimizationguide-pa.googleapis.com	Percentage of slow responses	60 %
Info	Informational	https://update.googleapis.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://update.googleapis.com	Percentage of endpoints with content type application/json	100 %
Info	Informational	https://update.googleapis.com	Percentage of endpoints with method POST	100 %

Level	Reason	Site	Description	Statistic
Info	Informational	https://update.googleapis.com	Count of total endpoints	5
Info	Informational	https://update.googleapis.com	Percentage of slow responses	15 %
Info	Informational	https://www.google.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://www.google.com	Percentage of endpoints with content type application/x-protobuf	100 %
Info	Informational	https://www.google.com	Percentage of endpoints with method GET	100 %
Info	Informational	https://www.google.com	Count of total endpoints	1
Info	Informational	https://www.googleapis.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://www.googleapis.com	Percentage of endpoints with content type application/json	100 %

Level	Reason	Site	Description	Statistic
Info	Informational	https://www.googleapis.com	Percentage of endpoints with method POST	100 %
Info	Informational	https://www.googleapis.com	Count of total endpoints	1
Info	Informational	https://www.googleapis.com	Percentage of slow responses	100 %

Alerts

Risk=Medium, Confidence=High (1)

<http://16.171.226.110:8080> (1)

[Content Security Policy \(CSP\) Header Not Set](#) (1)

► GET <http://16.171.226.110:8080/>

Risk=Medium, Confidence=Medium (2)

<http://16.171.226.110:8080> (2)

[Buffer Overflow](#) (1)

▼ PUT <http://16.171.226.110:8080/api/auth/me>

Alert tags

▪ [OWASP 2021 A03](#)

- [PCI DSS](#)
- POLICY_API =
- POLICY_PENTEST =
- [OWASP 2017 A01](#)
- [CWE-120](#)

Alert description

Buffer overflow errors are characterized by the overwriting of memory spaces of the background web process, which should have never been modified intentionally or unintentionally. Overwriting values of the IP (Instruction Pointer), BP (Base Pointer) and other registers causes exceptions, segmentation faults, and other process errors to occur. Usually these errors end execution of the application in an unexpected way.

Other info

Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error.

Request

▼ Request line and header section (687 bytes)

```
PUT
http://16.171.226.110:8080/api/auth/me HTTP/1.1
host: 16.171.226.110:8080
Connection: keep-alive
content-length: 2186
sec-ch-ua-platform: "macOS"
User-Agent: Mozilla/5.0
(Macintosh; Intel Mac OS X
10_15_7) AppleWebKit/537.36
(KHTML, like Gecko)
Chrome/147.0.0.0 Safari/537.36
sec-ch-ua: "Google
Chrome";v="147",
"Not.A/Brand";v="8",
"Chromium";v="147"
Content-Type: application/json
```


sec-ch-ua-mobile: ?0
Accept: */*
Origin:
https://16.171.226.110:8080
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer:
https://16.171.226.110:8080/profile
Accept-Language: en-GB,en-US;q=0.9,en;q=0.8
Cookie:
JSESSIONID=1972F26968E5BDD16EAD548545E3EC55

► Request body (2186 bytes)

Response

▼ Status line and header section (125 bytes)

HTTP/1.1 500
Content-Type: application/json
Date: Sun, 12 Apr 2026 06:59:14 GMT
Connection: close
content-length: 107

▼ Response body (107 bytes)

```
{"timestamp":"2026-04-12T06:59:14.954Z","status":500,"error":"Internal Server Error","path":"/api/auth/me"}
```

Parameter

fname

Attack

xGZ0EpRZWpdqMgXamILplmoRkSpnQfgLJrpCKsWp0GhnACFULqPgSTgnrFsSuUmdCL00CuWTpf fZmUVmJOIfVBQfhBHuudFBDMSyHt

dh0UDPoyikspgtytawewMenPanTeAIpZrw
sBqVPgCg0tcofEtqDBGWiYjLxqPuNtVFeq
isfyBhUUXULNLbiptlwgppIliaDRecMZFj
FMLwojQphyEdWQFRetfJfGokXFvuxRaXmR
bRk0uodXLmcpmAXchaynDRcLiLVlKSyEoc
JkUrDaybiLEbNcwUpbdQcbaiGHVtEeMuZN
hDbbqKQfSFFxtxTNfiTlOJAbmTgOmInKIc
TiryqcRxFyYKKjgBSMcPpUDKNhDNMJtJhM
sRKe00ftrAMUkxsIQZQTWnTarvBExbIVQp
AqLRiueTKEWKOdvkIGoWsuGwuiWYrNsdAA
mRkcHEAuTqQc0UihtosdPSUlaeKmWwJXto
qbxxfTPPyKTiuDMhd0UduhtPfKMXMZSwLR
KYQTFrMmQHkPEcGQyWFKZSuBBAYnTSpofp
eqERYLpyJtskXWrfUQjHlamQLHvpHylnBV
vcnemDaQrHQkWleDBLsVBGRcePewtWakJs
awAyFxAAPDCtbYVCKKrNPTPrsJfveSqBmC
sJtQwYEvKIJeQwrPCJoasQbJubZABQeWAE
IoyaLaMtVbPiSpLihXdDLTboAcEbXaWoMj
KAJMJsuZpKLIuKxKuvxVatygBFFJymtyUL
vQPfulvqtnrdXIHTAITUd0Zf0sDVUySVpD
VXaxAEwTIVsVh0NyFPwfHdFxxgPmiQ0AJA0
tonihZnsJeVdSJcQXDnpsTvfNtZacvihNy
0oTtMLxHsKmAeyOURVQhxhuaHRyDGuuckT
OX0UvkYkNJgxAJAVr0hqctdZCWwfbAbNxx
UsnJfqdGKhxtQQjLCiHrJyUrApkZsXWmsJ
yVlFfVGoEZQL0irtMKomZcMuToCsvguyXht
MslBbNMKUdJZjeZDMNLia0eqecxIbYNRXG
wiYmfnLwGiVyknJdhpsakCPTebDWvnYQU
PimqhJhTvuiVYleycDoHuuapbbekjYahMX
FORidjVtAyPqThjSsefNqYRjNATCyNhKmb
kBLEmm0ZDLIqKUhrAiJRuxCsAESpVDZiYD
TFnLs0cjWNuuDiJCbDa0LbvyfdUuXLSgY0
sZyvPNiWaImwCdmXvGuLltUaGMStSVCsDF
tU0gWGJpSRC0jyHCffhWtCawPdEYpChyHT
fBiDWv0GoKRSEAbORXsxRddxdsHCXCQwHp
arUCeqPkgRfRQts0UNVCEKwvBkfPKuovNh
FjTyotAGCtFovJfYSRCxV0TFyUbRmXxxUt
oYuZAYRwAqiATrVWsgnvoJHsbtJAVIiMrt
ChorVhSUSsWTqHVLTRIadiSZxrBSJPsxXBh
dqKVWddkCEUVRfNuNdqikYgmHmSvnpuHTH
puZfAHAfDeKxqihVJwPgSdc0cVrsRnkLOR
gkpBDQkeEJSgMLEgyfPMCBbU0tjJetETGw
GAdIiklHRYEcuPXvpNPFYxYGXEBTadaWpC

HsqXHJLygaBlNLpeuubIfGaTCAjmwsmCTV
ibRoFStfbJBbWxirmwqbVZtNHIpMcJWSRV
gTULWZVM0IdhsVfAwSwwAlUWLXRce0aERB
ykdpnuYcfuyyFCwvIDyoZtTv0QAcDilyJC
yGGIvuJBCpXTpvWwjCuIpIPyyhKmeRgREI
lRqoQJGwDEGchunDRYuddHQQosaiCoHfsI
ICgXgLrcqvJdmJqKWNwikoVkrapToEryXZ
EDxWVAbRSAvQVKYMqqLqZAGdAMyLeqPUEs
SQJlIoWqQsBJeGIghXERfvAvsCEBtoBvgk
hEA0JfByYeLwFcCqFxZZqsMYpNSnNBuAkg
sTNxEAlAXTiYWrcLZofnSnZyMZpQVBVKEk
mK0C0SpxdTsuLlRZwVD0IIInUTjoiAlxofe
uiHsiUIEBHDunIDbofJK0oyEuSmdnUgXa0
PyLkimvfaQQEfE0cUojqLY0VEBHSNjnsxU
oGjkEvQyqLBmeKMcAsgmVIxwjIdQmeVWhR
nZhyIdKVNdvJQxveDwuowphLIM

Evidence

Connection: close

Solution

Rewrite the background program using proper return length checking. This will require a recompile of the background executable.

Missing Anti-clickjacking Header (1)

▼ GET http://16.171.226.110:8080/

Alert tags

- [OWASP_2021_A05](#)
- POLICY_QA_STD =
- POLICY_PENTEST =
- [CWE-1021](#)
- [SYSTEMIC](#)
- [WSTG-v42-CLNT-09](#)
- [OWASP_2017_A06](#)

**Alert
description**

The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.

Request

▼ Request line and header section (668 bytes)

```
GET http://16.171.226.110:8080/
HTTP/1.1
host: 16.171.226.110:8080
Connection: keep-alive
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0
(Macintosh; Intel Mac OS X
10_15_7) AppleWebKit/537.36
(KHTML, like Gecko)
Chrome/147.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,ap
plication/xml;q=0.9,image/avif,ima
ge/webp,image/apng,*/*;q=0.8,appli
cation/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
sec-ch-ua: "Google
Chrome";v="147",
"Not.A/Brand";v="8",
"Chromium";v="147"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "macOS"
Accept-Language: en-GB,en-
US;q=0.9,en;q=0.8
```

▼ Request body (0 bytes)

Response

▼ Status line and header section (254 bytes)

```
HTTP/1.1 200
Last-Modified: Tue, 24 Mar 2026
13:42:40 GMT
Accept-Ranges: bytes
Content-Type:
```

```
text/html; charset=UTF-8
Content-Language: en-GB
Content-Length: 644
Date: Sun, 12 Apr 2026 06:45:48
GMT
Keep-Alive: timeout=60
Connection: keep-alive
```

▼ Response body (644 bytes)

```
<!doctype html><html lang="en">
<head><meta charset="utf-8"/>
<link rel="icon"
href="/favicon.ico"/><meta
name="viewport"
content="width=device-
width,initial-scale=1"/><meta
name="theme-color"
content="#000000"/><meta
name="description" content="Web
site created using create-react-
app"/><link rel="apple-touch-
icon" href="/logo192.png"/><link
rel="manifest"
href="/manifest.json"/>
<title>React App</title><script
defer="defer"
src="/static/js/main.8e7ad6c5.js">
</script><link
href="/static/css/main.5c6a9a18.cs
s" rel="stylesheet"></head><body>
<noscript>You need to enable
JavaScript to run this app.
</noscript><div id="root"></div>
</body></html>
```

Parameter

x-frame-options

Solution

Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of

them is set on all web pages returned by your site/app.

If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.

Risk=Low, Confidence=Medium (2)

<http://16.171.226.110:8080> (2)

Cookie without SameSite Attribute (1)

▼ GET <http://16.171.226.110:8080/api/auth/me>

Alert tags

- [OWASP 2021 A01](#)
- POLICY_QA_STD =
- [WSTG-v42-SESS-02](#)
- POLICY_PENTEST =
- [SYSTEMIC](#)
- [CWE-1275](#)
- [OWASP 2017 A05](#)
- POLICY_DEV_STD =

**Alert
description**

A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks.

Request

▼ Request line and header section (536 bytes)

GET
http://16.171.226.110:8080/api/auth/me HTTP/1.1
host: 16.171.226.110:8080
Connection: keep-alive
sec-ch-ua-platform: "macOS"
User-Agent: Mozilla/5.0
(Macintosh; Intel Mac OS X
10_15_7) AppleWebKit/537.36
(KHTML, like Gecko)
Chrome/147.0.0.0 Safari/537.36
sec-ch-ua: "Google
Chrome";v="147",
"Not.A/Brand";v="8",
"Chromium";v="147"
sec-ch-ua-mobile: ?0
Accept: */*
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer:
https://16.171.226.110:8080/
Accept-Language: en-GB,en-
US;q=0.9,en;q=0.8

▼ Request body (0 bytes)

Response

▼ Status line and header section (236 bytes)

HTTP/1.1 401
Set-Cookie:
JSESSIONID=1972F26968E5BDD16EAD54
8545E3EC55; Path=/; HttpOnly
Content-Type:
text/plain; charset=UTF-8
Content-Length: 13
Date: Sun, 12 Apr 2026 06:45:50
GMT
Keep-Alive: timeout=60

Connection: keep-alive

▼ Response body (13 bytes)

Not logged in

Parameter

JSESSIONID

Evidence

Set-Cookie: JSESSIONID

Solution

Ensure that the SameSite attribute is set to either 'lax' or ideally 'strict' for all cookies.

X-Content-Type-Options Header Missing (1)

▼ GET http://16.171.226.110:8080/

Alert tags

- [OWASP_2021_A05](#)
- POLICY_QA_STD =
- POLICY_PENTEST =
- [SYSTEMIC](#)
- [CWE-693](#)
- [OWASP_2017_A06](#)

**Alert
description**

The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.

Other info

This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by

injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.

At "High" threshold this scan rule will not alert on client or server error responses.

Request

▼ Request line and header section (668 bytes)

```
GET http://16.171.226.110:8080/
HTTP/1.1
host: 16.171.226.110:8080
Connection: keep-alive
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0
(Macintosh; Intel Mac OS X
10_15_7) AppleWebKit/537.36
(KHTML, like Gecko)
Chrome/147.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
sec-ch-ua: "Google
Chrome";v="147",
"Not.A/Brand";v="8",
"Chromium";v="147"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "macOS"
Accept-Language: en-GB,en-
US;q=0.9,en;q=0.8
```

▼ Request body (0 bytes)

Response

▼ Status line and header section (254 bytes)

```
HTTP/1.1 200
Last-Modified: Tue, 24 Mar 2026
13:42:40 GMT
Accept-Ranges: bytes
Content-Type:
text/html; charset=UTF-8
Content-Language: en-GB
Content-Length: 644
Date: Sun, 12 Apr 2026 06:45:48
GMT
Keep-Alive: timeout=60
Connection: keep-alive
```

▼ Response body (644 bytes)

```
<!doctype html><html lang="en">
<head><meta charset="utf-8"/>
<link rel="icon"
href="/favicon.ico"/><meta
name="viewport"
content="width=device-
width,initial-scale=1"/><meta
name="theme-color"
content="#000000"/><meta
name="description" content="Web
site created using create-react-
app"/><link rel="apple-touch-
icon" href="/logo192.png"/><link
rel="manifest"
href="/manifest.json"/>
<title>React App</title><script
defer="defer"
src="/static/js/main.8e7ad6c5.js">
</script><link
href="/static/css/main.5c6a9a18.cs
s" rel="stylesheet"></head><body>
<noscript>You need to enable
JavaScript to run this app.
```

```
</noscript><div id="root"></div>
</body></html>
```

Parameter

x-content-type-options

Solution

Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages.

If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.

Risk=Informational, Confidence=High (1)

<http://16.171.226.110:8080> (1)

Authentication Request Identified (1)

▼ POST <http://16.171.226.110:8080/api/auth/login>

Alert tags**Alert
description**

The given request has been identified as an authentication request. The 'Other Info' field contains a set of key=value lines which identify any relevant fields. If the request is in a context which has an Authentication Method set to "Auto-Detect" then this rule will change the authentication to match the request identified.

Other info

userParam=email

userValue=test@fligh.com

passwordParam=password

referer=https://16.171.226.110:8080/

Request

▼ Request line and header section (682 bytes)

POST

http://16.171.226.110:8080/api/auth/login HTTP/1.1

host: 16.171.226.110:8080

Connection: keep-alive

Content-Length: 49

sec-ch-ua-platform: "macOS"

User-Agent: Mozilla/5.0

(Macintosh; Intel Mac OS X

10_15_7) AppleWebKit/537.36

(KHTML, like Gecko)

Chrome/147.0.0.0 Safari/537.36

sec-ch-ua: "Google

Chrome";v="147",

"Not.A/Brand";v="8",

"Chromium";v="147"

Content-Type: application/json

sec-ch-ua-mobile: ?0

Accept: */*

Origin:

https://16.171.226.110:8080

Sec-Fetch-Site: same-origin

Sec-Fetch-Mode: cors

Sec-Fetch-Dest: empty

Referer:

https://16.171.226.110:8080/

Accept-Language: en-GB,en-US;q=0.9,en;q=0.8

Cookie:

JSESSIONID=1972F26968E5BDD16EAD548545E3EC55

▼ Request body (49 bytes)

```
{"email":"test@fligh.com","password":"Admin@123"}
```

Response

▼ Status line and header section (154 bytes)

```
HTTP/1.1 200
Content-Type: application/json
Date: Sun, 12 Apr 2026 06:48:08 GMT
Keep-Alive: timeout=60
Connection: keep-alive
content-length: 138
```

▼ Response body (138 bytes)

```
{"country":"India","dob":"2026-04-12","email":"test@fligh.com","fname":"Mohan","id":22,"lname":"Kumar","phone":"8999212356","role":"USER"}
```

Parameter

email

Evidence

password

Solution

This is an informational alert rather than a vulnerability and so there is nothing to fix.

Risk=Informational, Confidence=Medium (3)

<http://16.171.226.110:8080> (3)

Modern Web Application (1)

▼ GET <http://16.171.226.110:8080/>

Alert tags

- POLICY_QA_STD =
- POLICY_PENTEST =
- [SYSTEMIC](#)
- POLICY_DEV_STD =

Alert description

The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.

Other info

No links have been found while there are scripts, which is an indication that this is a modern web application.

Request

▼ Request line and header section (668 bytes)

```
GET http://16.171.226.110:8080/
HTTP/1.1
host: 16.171.226.110:8080
Connection: keep-alive
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0
(Macintosh; Intel Mac OS X
10_15_7) AppleWebKit/537.36
(KHTML, like Gecko)
Chrome/147.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
sec-ch-ua: "Google
Chrome";v="147",
"Not.A/Brand";v="8",
"Chromium";v="147"
sec-ch-ua-mobile: ?0
```

```
sec-ch-ua-platform: "macOS"  
Accept-Language: en-GB,en-US;q=0.9,en;q=0.8
```

▼ Request body (0 bytes)

Response

▼ Status line and header section (254 bytes)

```
HTTP/1.1 200  
Last-Modified: Tue, 24 Mar 2026  
13:42:40 GMT  
Accept-Ranges: bytes  
Content-Type:  
text/html; charset=UTF-8  
Content-Language: en-GB  
Content-Length: 644  
Date: Sun, 12 Apr 2026 06:45:48  
GMT  
Keep-Alive: timeout=60  
Connection: keep-alive
```

▼ Response body (644 bytes)

```
<!doctype html><html lang="en">  
<head><meta charset="utf-8"/>  
<link rel="icon"  
href="/favicon.ico"/><meta  
name="viewport"  
content="width=device-  
width,initial-scale=1"/><meta  
name="theme-color"  
content="#000000"/><meta  
name="description" content="Web  
site created using create-react-  
app"/><link rel="apple-touch-  
icon" href="/logo192.png"/><link  
rel="manifest"  
href="/manifest.json"/>  
<title>React App</title><script
```

```
defer="defer"
src="/static/js/main.8e7ad6c5.js">
</script><link
href="/static/css/main.5c6a9a18.cs
s" rel="stylesheet"></head><body>
<noscript>You need to enable
JavaScript to run this app.
</noscript><div id="root"></div>
</body></html>
```

Evidence

```
<script defer="defer"
src="/static/js/main.8e7ad6c5.js">
</script>
```

Solution

This is an informational alert and so no changes are required.

Session Management Response Identified (1)

▼ GET http://16.171.226.110:8080/api/auth/me

Alert tags

**Alert
description**

The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.

Other info

cookie:JSESSIONID

Request

▼ Request line and header section (536 bytes)

GET
http://16.171.226.110:8080/api/au


```
th/me HTTP/1.1
host: 16.171.226.110:8080
Connection: keep-alive
sec-ch-ua-platform: "macOS"
User-Agent: Mozilla/5.0
(Macintosh; Intel Mac OS X
10_15_7) AppleWebKit/537.36
(KHTML, like Gecko)
Chrome/147.0.0.0 Safari/537.36
sec-ch-ua: "Google
Chrome";v="147",
"Not.A/Brand";v="8",
"Chromium";v="147"
sec-ch-ua-mobile: ?0
Accept: */*
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer:
https://16.171.226.110:8080/
Accept-Language: en-GB,en-
US;q=0.9,en;q=0.8
```

▼ Request body (0 bytes)

Response

▼ Status line and header section (236 bytes)

```
HTTP/1.1 401
Set-Cookie:
JSESSIONID=1972F26968E5BDD16EAD54
8545E3EC55; Path=/; HttpOnly
Content-Type:
text/plain; charset=UTF-8
Content-Length: 13
Date: Sun, 12 Apr 2026 06:45:50
GMT
Keep-Alive: timeout=60
Connection: keep-alive
```

▼ Response body (13 bytes)

Not logged in

Parameter JSESSIONID

Evidence JSESSIONID

Solution This is an informational alert rather than a vulnerability and so there is nothing to fix.

User Agent Fuzzer (1)

▼ POST http://16.171.226.110:8080/api/auth/login

Alert tags

- CUSTOM_PAYLOADS =
- POLICY_PENTEST =
- [SYSTEMIC](#)

Alert description Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the response body with the original response.

Request ▼ Request line and header section (615 bytes)

```
POST
http://16.171.226.110:8080/api/auth/login HTTP/1.1
host: 16.171.226.110:8080
Connection: keep-alive
Content-Length: 49
sec-ch-ua-platform: "macOS"
user-agent: Mozilla/4.0
(compatible; MSIE 8.0; Windows
NT 6.1)
sec-ch-ua: "Google
Chrome";v="147",
```

```
"Not.A/Brand";v="8",
"Chromium";v="147"
Content-Type: application/json
sec-ch-ua-mobile: ?0
Accept: */*
Origin:
https://16.171.226.110:8080
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer:
https://16.171.226.110:8080/
Accept-Language: en-GB,en-
US;q=0.9,en;q=0.8
Cookie:
JSESSIONID=1972F26968E5BDD16EAD54
8545E3EC55
```

▼ Request body (49 bytes)

```
{"email":"test@fligh.com","password":"Admin@123"}
```

Response

▼ Status line and header section (154 bytes)

```
HTTP/1.1 200
Content-Type: application/json
Date: Sun, 12 Apr 2026 06:59:40
GMT
Keep-Alive: timeout=60
Connection: keep-alive
content-length: 198
```

▼ Response body (198 bytes)

```
{"country":"India","dob":"2026-
04-
12","email":"test@fligh.com","fna
me":"Mohana","id":22,"lname":"\"/
><xsl:value-of select=\"system-
```

	<pre>property('xsl:vendor')\"/><!-- ","phone":"8999212356","role":"US ER"} </pre>
Parameter	Header User-Agent
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)

Appendix

Alert Types

This section contains additional information on the types of alerts in the report.

Buffer Overflow

Source	raised by an active scanner (Buffer Overflow)
CWE ID	120
WASC ID	7
Reference	▪ https://owasp.org/www-community/attacks/Buffer_overflow_attack

Content Security Policy (CSP) Header Not Set

Source	raised by a passive scanner (Content Security Policy (CSP) Header Not Set)
CWE ID	693
WASC ID	15

Reference

- <https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP>
- https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html
- <https://www.w3.org/TR/CSP/>
- <https://w3c.github.io/webappsec-csp/>
- <https://web.dev/articles/csp>
- <https://caniuse.com/#feat=contentsecuritypolicy>
- <https://content-security-policy.com/>

Missing Anti-clickjacking Header

Source	raised by a passive scanner (Anti-clickjacking Header)
CWE ID	1021
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options

Cookie without SameSite Attribute

Source	raised by a passive scanner (Cookie without SameSite Attribute)
CWE ID	1275
WASC ID	13

Reference	▪ https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site
------------------	---

X-Content-Type-Options Header Missing

Source	raised by a passive scanner (X-Content-Type-Options Header Missing)
CWE ID	693
WASC ID	15
Reference	▪ https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) ▪ https://owasp.org/www-community/Security-Headers

Authentication Request Identified

Source	raised by a passive scanner (Authentication Request Identified)
Reference	▪ https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/

Modern Web Application

Source	raised by a passive scanner (Modern Web Application)
---------------	--

Session Management Response Identified

Source	raised by a passive scanner (Session Management Response Identified)
---------------	--

Reference

- <https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/>

User Agent Fuzzer

Source

raised by an active scanner ([User Agent Fuzzer](#))

Reference

- <https://owasp.org/wstg>